



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Sites: <https://firefox-settings-attachments.cdn.mozilla.net> <http://172.30.20.2:8161>

Generated on Sun, 26 Jul 2026 17:40:57

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	2
Informational	1
False Positives:	0

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Weak Authentication Method	Medium	1
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://172.30.20.2:8161/demo/
Node Name	http://172.30.20.2:8161/demo/

Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.30.20.2:8161/sitemap.xml
Node Name	http://172.30.20.2:8161/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.30.20.2:8161/sitemap.xml..
Node Name	http://172.30.20.2:8161/sitemap.xml..
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.30.20.2:8161/sitemap.xml....
Node Name	http://172.30.20.2:8161/sitemap.xml....
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Weak Authentication Method
Description	HTTP basic or digest authentication has been used over an unsecured connection. The credentials can be read and then reused by someone with access to the network.
URL	http://172.30.20.2:8161/admin/

Node Name	http://172.30.20.2:8161/admin/
Method	GET
Attack	
Evidence	www-authenticate: basic realm="ActiveMQRealm"
Other Info	
Instances	1
Solution	Protect the connection using HTTPS or use a stronger authentication mechanism.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
CWE Id	326
WASC Id	4
Plugin Id	10105

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	http://172.30.20.2:8161/demo/
Node Name	http://172.30.20.2:8161/demo/
Method	GET
Attack	
Evidence	Jetty(9.2.13.v20150730)
Other Info	
URL	http://172.30.20.2:8161/sitemap.xml
Node Name	http://172.30.20.2:8161/sitemap.xml
Method	GET
Attack	
Evidence	Jetty(9.2.13.v20150730)
Other Info	
URL	http://172.30.20.2:8161/sitemap.xml..
Node Name	http://172.30.20.2:8161/sitemap.xml..
Method	GET
Attack	
Evidence	Jetty(9.2.13.v20150730)
Other Info	
URL	http://172.30.20.2:8161/sitemap.xml...
Node Name	http://172.30.20.2:8161/sitemap.xml...
Method	GET

Attack	
Evidence	Jetty(9.2.13.v20150730)
Other Info	
URL	http://172.30.20.2:8161/sitemap.xml....
Node Name	http://172.30.20.2:8161/sitemap.xml....
Method	GET
Attack	
Evidence	Jetty(9.2.13.v20150730)
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://172.30.20.2:8161
Node Name	http://172.30.20.2:8161
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.20.2:8161/images/white-header-left.png
Node Name	http://172.30.20.2:8161/images/white-header-left.png
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

	At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.20.2:8161/styles/prettify.css
Node Name	http://172.30.20.2:8161/styles/prettify.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.20.2:8161/styles/site.css
Node Name	http://172.30.20.2:8161/styles/site.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.20.2:8161/styles/sorttable.css
Node Name	http://172.30.20.2:8161/styles/sorttable.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

URL	http://172.30.20.2:8161/images
Node Name	http://172.30.20.2:8161/images
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://172.30.20.2:8161/styles
Node Name	http://172.30.20.2:8161/styles
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://172.30.20.2:8161/styles
Node Name	http://172.30.20.2:8161/styles
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104